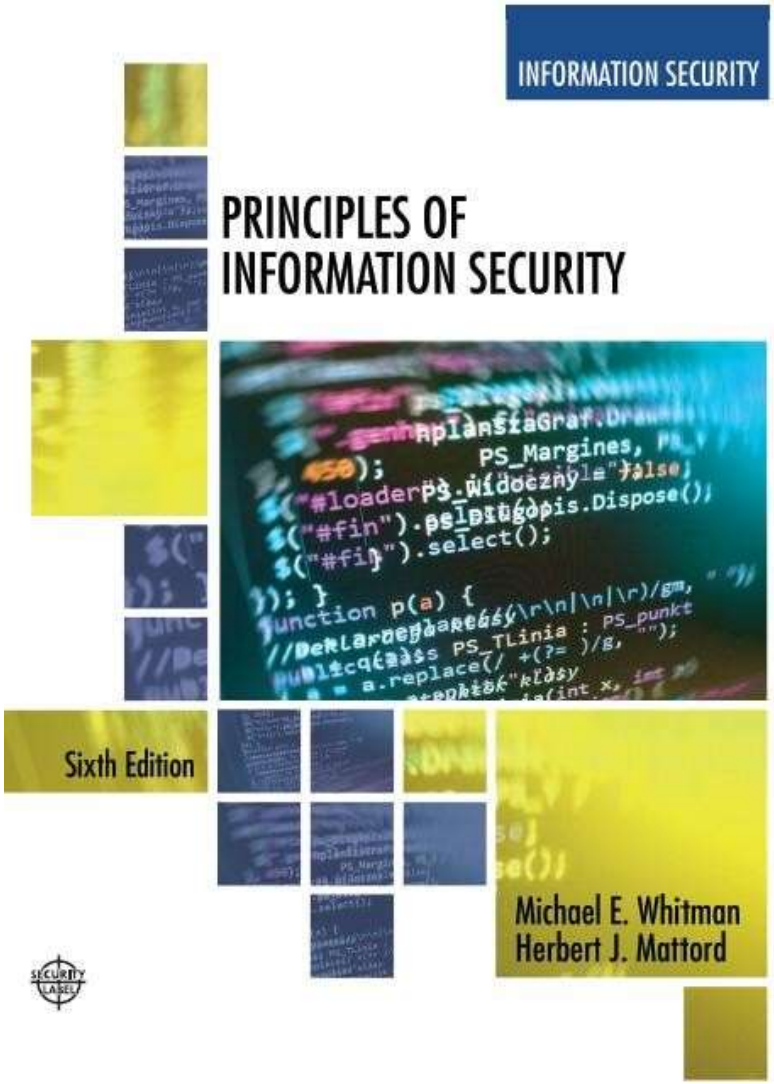
Principles of Information Security

Sixth Edition



Chapter 1

Introduction to Information Security

CENGAGE Learning

Copyright © 2018 Cengage. May not be copied, scanned, or duplicated, in whole or in part, except for use as permitted in a license distributed with a certain product or service or otherwise on a password-protected website for classroom use.

What Is Security?

“The quality or state of being secure–to be free from danger”

A successful organization should have multiple layers of security in place, the idea is that if hackers want to access the data, they have to break through multiple layers of security, making it much more difficult to gain access.

Physical security

✓ to protect physical items, objects, or areas from unauthorized access and misuse

Personal security

✓ to protect the individual or group of individuals who are authorized to access the organization and its operations

What Is Security?

Operations security

✓ to protect the details of a particular operation or series of activities

Communications security

✓ to protect communications media, technology, and content

Network security

✓to protect networking components, connections, and contents

Information security

✓to protect the confidentiality, integrity and availability of information assets, whether in storage, processing, or transmission. It is achieved via the application of policy, education, training and awareness, and technology.

What is information Security?

- The protection of information and its critical elements, including systems and hardware that use, store, and transmit that information
- Includes information security management, data security, and network security
- C.I.A. triangle
  - Is a standard based on confidentiality, integrity, and availability.

CENGAGE Learning

Copyright © 2018 Cengage. May not be copied, scanned, or duplicated, in whole or in part, except for use as permitted in a license distributed with a certain product or service or otherwise on a password-protected website for classroom use.

Components of information security

CENGAGE Learning
Copyright © 2018 Cengage. May not be copied, scanned, or duplicated, in whole or in part, except for use as permitted in a license distributed with a certain product or service or otherwise on a password-protected website for classroom use.

Components of information security

- **Confidentiality**

✓(its one of the three components of the CIA triangle, it used for assurance that the information is shared only among authorized persons or organizations)

✓To protect the confidentiality of information, you can use a number of measures, including the following:

i. Information classification.

ii. Secure document storage.

iii. Application of general security policies.

iv. Education of information custodians and end users.

Components of information security

- **Integrity**

✓its one of the three components of the CIA triangle, it used for assurance that the information is complete and uncorrupted.

- **Availability**

✓(its one of the three components of the CIA triangle, it used for assurance that the information systems and the necessary data are available for use when they are needed).

✓ Availability enables authorized users—persons or computer systems—to access information without interference or obstruction and to receive it in the required format.

Key Information Security Concepts

- **Access:**

✓A subject or object's ability to use, manipulate, modify, or affect another subject or object.

✓Authorized users have legal access to a system, whereas hackers have illegal access to a system.

✓Access controls regulate this ability.

- **Asset.**

✓The organizational resource that is being protected.

✓An asset can be logical, such as a Web site, information, or data; or an asset can be physical, such as a person, computer system, or other tangible object.

Key Information Security Concepts

- **Attacks**

✓ Act or action that exploits vulnerability (i.e., an identified weakness) in controlled system

✓ Accomplished by **threat agent** that damages or steals organization's information

➢ **A direct attack** is a hacker using a personal computer to break into a system.

➢ **An indirect attack** is a hacker compromising a system and using it to attack other systems.

Key Information Security Concepts

Attacks (continued)

1- Malicious code: includes execution of viruses, worms, Trojan horses, and active Web scripts with intent to destroy or steal information

2- Hoaxes : transmission of a virus hoax with a real virus attached; more devious form of attack

3- Back door: gaining access to system or network using known or previously unknown/newly discovered access mechanism

Key Information Security Concepts

Attacks (continued)

4- Password attacks include:

i. Password crack: attempting to reverse calculate a password

ii. Brute force: trying every possible combination of options of a password

iii. Dictionary: selects specific accounts to attack and uses commonly used passwords (i.e., the dictionary) to guide guesses

Key Information Security Concepts

Attacks (continued)

- **To protect against password attacks**, security administrators can:
  - Implement controls that limit the number of attempts allowed.
  - Use a “disallow” list of passwords from a similar dictionary.
  - Require use of additional numbers and special characters in passwords.

Key Information Security Concepts

Attacks (continued)

5- Denial-of-service (DoS) attack: occurs when an attacker sends a large number of connection or information requests to a target.

6- Distributed denial-of-service (DDoS) attack: occurs when a coordinated stream of requests is launched against a target from many locations at the same time.

“ A DDoS attacks are more dangerous and harmful than DoS attacks because they originate from several systems, whereas DoS attacks originate from a single system. Therefore, it becomes more difficult for security products and teams to identify the origin of an attack..”

Key Information Security Concepts

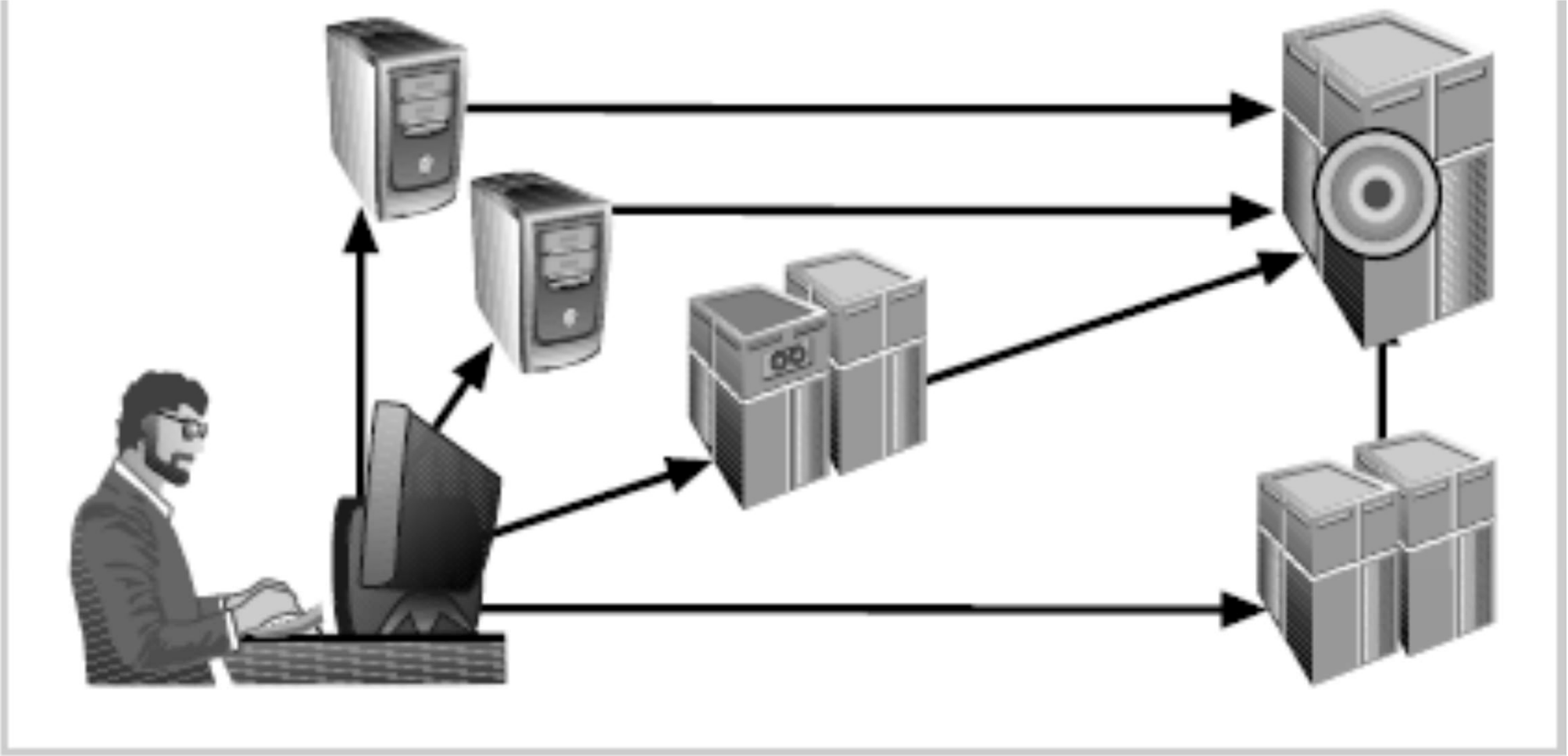


Figure 2-11 Denial-of-Service Attacks

Key Information Security Concepts

Attacks (continued)

7- Spoofing : technique used to gain unauthorized access; intruder assumes a trusted IP address

8- Man-in-the-middle: attacker monitors network packets, modifies them, and inserts them back into network

9- Spam: unsolicited commercial e-mail; more a nuisance than an attack, though is emerging as a vector for some attacks

Key Information Security Concepts

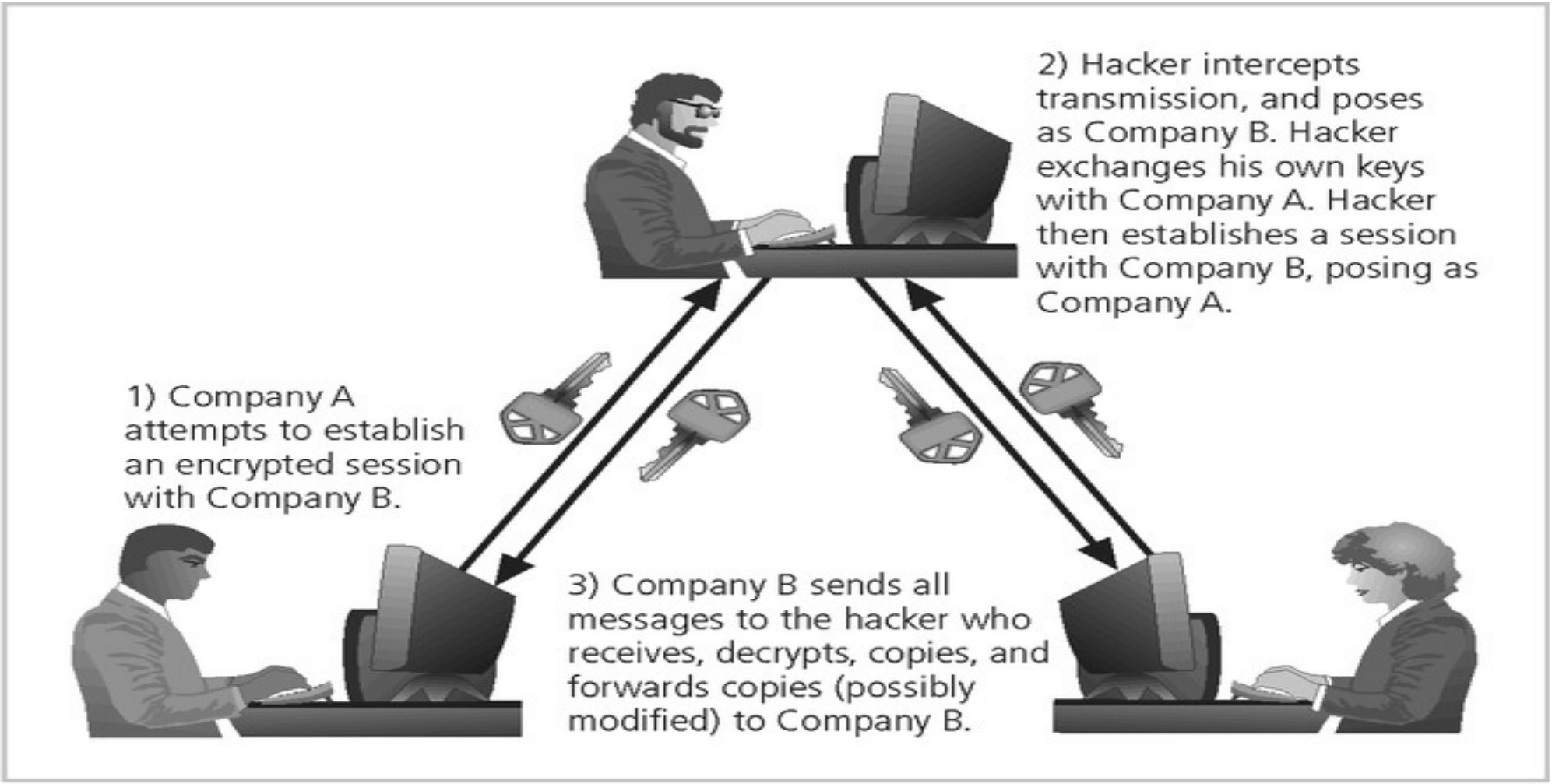


FIGURE 2-11 Man-in-the-Middle Attack

Key Information Security Concepts

Attacks (continued)

10- Mail bombing: also a DoS; attacker routes large quantities of e-mail to target

11- Sniffers : program or device that monitors data travelling over network; can be used both for legitimate purposes and for stealing information from a network

12- Social engineering: using social skills to convince people to reveal access credentials or other valuable information to attacker

Key Information Security Concepts

Attacks (continued)

13- (Spear) Phishing: an attempt to gain personal/financial information from individual, usually by posing as legitimate entity

14- Pharming: redirection of legitimate Web traffic (e.g., browser requests) to illegitimate site for the purpose of obtaining private information

15- Timing attack : relatively new; works by exploring contents of a Web browser's cache to create malicious cookie

Key Information Security Concepts

- **Control, safeguard, or countermeasure:**
  - ✓Security mechanisms, policies, or procedures that can successfully counter attacks, reduce risk, resolve vulnerabilities, and otherwise improve the security within an organization.
- **loss.**
  - ✓ is any process or event that results in information being corrupted, deleted and/or made unreadable by a user and/or software or application.

Key Information Security Concepts

- **Exploit.**

  ✓A technique used to compromise a system.

  ✓an exploit can be a documented process to take advantage of a vulnerability or exposure, usually in software, that is either inherent in the software or is created by the attacker.

- **Exposure.**

  ✓In information security, exposure exists when a vulnerability known to an attacker is present.

Key Information Security Concepts

- **Protection profile or security posture:**
  - ✓The entire set of controls and safeguards, including policy, education, training and awareness, and technology, that the organization implements (or fails to implement) to protect the asset.
- **Risk:**
  - ✓The probability that something unwanted will happen.
- **Subjects and objects:**
  - ✓computer can be both the subject and object of an attack, when, for example, it is compromised by an attack (object), and is then used to attack other systems (subject).

Key Information Security Concepts

- **Threat.**
  - ✓A category of objects, persons, or other entities that presents a danger to an asset.
  - ✓Threats are always present and can be purposeful or undirected. For example, hackers purposefully threaten unprotected information systems.
- **Threat agent.**
  - ✓A threat agent is the facilitator of an attack or a component of a threat.

Key Information Security Concepts

- **Vulnerability.**

✓A weaknesses or fault in a system or protection mechanism that opens it to attack or damage.

✓ The four main types of vulnerabilities in information security are: نقط **network vulnerabilities**, **operating system vulnerabilities**, **process** (or procedural) **vulnerabilities**, and **human vulnerabilities**.

Key Information Security Concepts

Causes Vulnerabilities.

1. **Human error** – When end users fall to social engineering , they become one of the biggest causes of vulnerabilities in security.
2. **Software bugs** – These are flaws in a code that cybercriminals can use to gain unauthorized access to hardware, software, data, or other assets in an organization's network.
3. **System complexity** – When a system is too complex, it causes vulnerability because there's an increased flaws, or unwanted network access.
4. **Increased connectivity** – Having so many remote devices connected to a network creates new access points for attacks.
5. **Poor access control** – like providing some users more access than they need to data and systems or not closing accounts for old employees, makes networks vulnerable from both inside and outside breaches.

Security in the Systems Development Life Cycle

- **Systems development life cycle (SDLC):**

  a methodology for the design and implementation of an information system

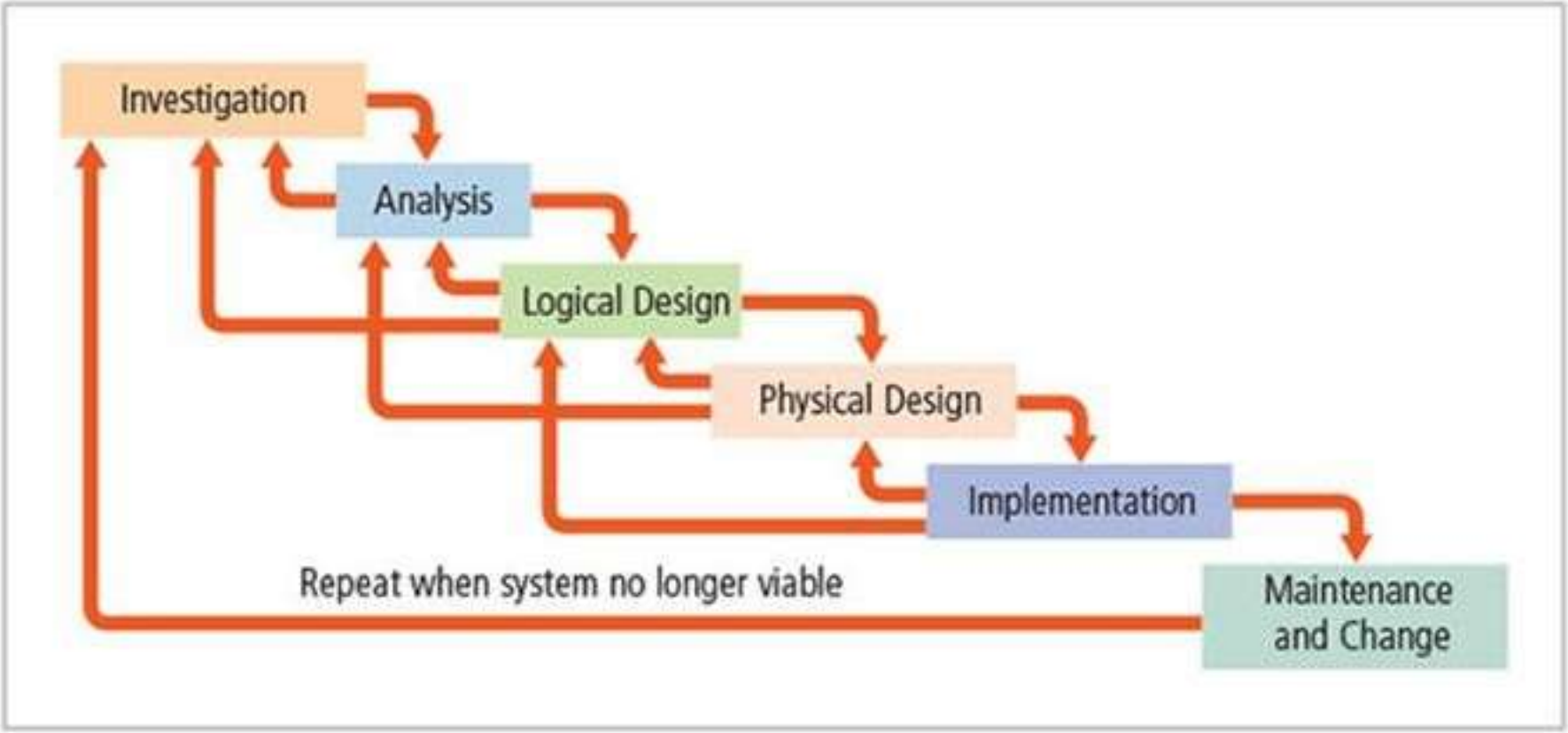
- **Methodology:** a formal approach to solving a problem based on a structured sequence of procedures

- **Using a methodology:**
  - Ensures a rigorous process with a clearly defined goal
  - Increases probability of success

CENGAGE Learning

Copyright © 2018 Cengage. May not be copied, scanned, or duplicated, in whole or in part, except for use as permitted in a license distributed with a certain product or service or otherwise on a password-protected website for classroom use.

Figure 1-13 SDLC waterfall methodology



© Cengage Learning 2015

CENGAGE Learning
Copyright © 2018 Cengage. May not be copied, scanned, or duplicated, in whole or in part, except for use as permitted in a license distributed with a certain product or service or otherwise on a password-protected website for classroom use.

Investigation

- What problem is the system being developed to solve?
- Objectives, constraints, and scope of project are specified.
- Preliminary cost-benefit analysis is developed.
- At the end of all phases, a process is undertaken to assess economic, technical, and behavioral feasibilities and ensure implementation is worth the time and effort.

CENGAGE Learning

Copyright © 2018 Cengage. May not be copied, scanned, or duplicated, in whole or in part, except for use as permitted in a license distributed with a certain product or service or otherwise on a password-protected website for classroom use.

Analysis

- Consists of assessments of:
  - The organization
  - Current systems
  - Capability to support proposed systems
- Analysts determine what the new system is expected to do and how it will interact with existing systems.
- Analysis ends with documentation of findings and an update of feasibility.

CENGAGE Learning

Copyright © 2018 Cengage. May not be copied, scanned, or duplicated, in whole or in part, except for use as permitted in a license distributed with a certain product or service or otherwise on a password-protected website for classroom use.

Logical Design

- The first and driving factor is the business need.
  - Applications are selected to provide needed services.
- Data support and structures capable of providing the needed inputs are identified.
- Specific technologies are delineated to implement the physical solution.
- Analysts generate estimates of costs and benefits to allow comparison of available options.
- Feasibility analysis is performed at the end.

CENGAGE Learning

Copyright © 2018 Cengage. May not be copied, scanned, or duplicated, in whole or in part, except for use as permitted in a license distributed with a certain product or service or otherwise on a password-protected website for classroom use.

Physical Design

- Specific technologies are selected to support the alternatives identified and evaluated in the logical design.
- Selected components are evaluated on make-or- buy decision.
- Feasibility analysis is performed.
- Entire solution is presented to organization's management for approval.

CENGAGE Learning

Copyright © 2018 Cengage. May not be copied, scanned, or duplicated, in whole or in part, except for use as permitted in a license distributed with a certain product or service or otherwise on a password-protected website for classroom use.

Implementation

- Needed software is created.
- Components are ordered, received, and tested.
- Users are trained and supporting documentation created.
- Feasibility analysis is prepared.
  - Sponsors are presented with the system for a performance review and acceptance test.

CENGAGE Learning

Copyright © 2018 Cengage. May not be copied, scanned, or duplicated, in whole or in part, except for use as permitted in a license distributed with a certain product or service or otherwise on a password-protected website for classroom use.

Maintenance and Change

- Longest and most expensive phase
- Consists of the tasks necessary to support and modify the system for the remainder of its useful life
- Life cycle continues until the team determines the process should begin again from the investigation phase
- When current system can no longer support the organization's mission, a new project is implemented

CENGAGE Learning

Copyright © 2018 Cengage. May not be copied, scanned, or duplicated, in whole or in part, except for use as permitted in a license distributed with a certain product or service or otherwise on a password-protected website for classroom use.